

Dependency & Supply-Chain Audit Trail Report

Project: vulnerable-invoice-service · Run date: 2026-06-26 · SHA: 61ed8c3 · Branch: fix/depSCAN-20260626-062022 · Mode: full

Executive Summary

CRITICAL → CLEARED All CRITICAL and supply-chain BLOCK findings from the Stage 1 scan have been resolved in this automated remediation run. The project transitions from a vulnerable baseline (3 CRITICAL, 5 HIGH, 2 MEDIUM findings) to a near-clean state (0 CRITICAL, 1 HIGH unresolvable — requires human review, 4 MEDIUM remaining).

Stage	Status	Key Output
Stage 1 — Dependency Scan	✔ Complete	10 findings: 3 CRITICAL, 5 HIGH, 2 MEDIUM
Stage 2 — Risk Scoring	✔ Complete	Top risk: log4j-core (score 9.0/10), jackson-databind (8.8/10)
Stage 3 — Auto-Remediation	✔ Complete	7 commits; 6 version bumps + 2 supply-chain removals
Stage 4 — Merge Gate	🔄 In Progress	Gate verdict posted to the fix PR

Stage 1 — Scan Findings (Baseline)

Scan date: 2026-06-26 · Scanner: Gripe 0.114.0 + Syft 1.45.1

ID	Coordinate	Version	Severity	Issue Type	CVEs	CVSS Max
FIND-001	org.apache.logging.log4j:log4j-core	2.14.1	CRITICAL	CVE	CVE-2021-44228, +6	10.0
FIND-007	org.apache.logging.log4j:log4j-api	2.14.1	CRITICAL	CVE	CVE-2021-44228, CVE-2021-45046	10.0
FIND-002	com.fasterxml.jackson.core:jackson-databind	2.9.8	CRITICAL	CVE	CVE-2019-12086, +54	9.8
FIND-003	mysql:mysql-connector-java	8.0.30	HIGH	CVE	CVE-2023-22102	8.9
FIND-008	mysql:mysql-connector-java	8.0.30	HIGH	LICENSE	GPL-2.0 violation	—
FIND-004	commons-io:commons-io	2.4	HIGH	CVE	CVE-2021-29425, CVE-2024-47554	8.7
FIND-009	com.fastxml.jackson.core:jackson-databind	2.9.8	HIGH	TYPOSQUATTED	—	—
FIND-010	repository:internal-untrusted-mirror	—	HIGH	UNTRUSTED_REPO	—	—
FIND-006	com.google.guava:guava	24.1.1-jre	MEDIUM	CVE	CVE-2020-8908, CVE-2023-2976	5.5
FIND-005	org.apache.commons:commons-lang3	3.4	MEDIUM	CVE	CVE-2025-48924	6.5

Supply-chain flags: FIND-009 (typosquatted coordinate — missing "er" in groupId, potential malware vector) and FIND-010 (plain HTTP repository — MITM artifact substitution risk) were both removed in Stage 3.

Stage 2 — Risk Score Rankings

Rank	Coordinate	Risk Score	Band	Top CVE	CVSS
1	log4j-core:2.14.1	9.0	CRITICAL	CVE-2021-44228 (Log4Shell)	10.0
2	log4j-api:2.14.1	9.0	CRITICAL	CVE-2021-44228 (Log4Shell)	10.0
3	jackson-databind:2.9.8	8.8	CRITICAL	CVE-2019-12086 (deser RCE)	9.8
4	mysql-connector-java:8.0.30 (CVE)	8.2	CRITICAL	CVE-2023-22102	8.9
5	mysql-connector-java:8.0.30 (LICENSE)	8.2	CRITICAL	GPL-2.0	—
6	commons-io:2.4	7.8	HIGH	CVE-2021-29425	8.7
7	guava:24.1.1-jre	6.2	HIGH	CVE-2020-8908	5.5
8	commons-lang3:3.4	6.1	HIGH	CVE-2025-48924	6.5
9	typosquat jackson-databind	4.0	MEDIUM	TYPOSQUATTED	—
10	untrusted HTTP repo	3.8	MEDIUM	UNTRUSTED_REPO	—

Stage 3 — Auto-Remediation

Branch: fix/depscan-20260626-062022 · **Commits:** 7 · **Build:** mvn clean test —  PASS (2/2 tests)

Fixes Applied

Coordinate	Action	Old → New	CVEs Cleared	Status
com.fastxml.jackson.core:jackson-databind	REMOVED	2.9.8 → removed	TYPOSQUATTED	 Included
repository:internal-untrusted-mirror	REMOVED	HTTP → removed	UNTRUSTED_REPO	 Included
org.apache.logging.log4j:log4j-core	Version bump	2.14.1 → 2.17.1	CVE-2021-44228, CVE-2021-45046, CVE-2021-44832, CVE-2021-45105	 Included
org.apache.logging.log4j:log4j-api	Version bump (lockstep)	2.14.1 → 2.17.1	CVE-2021-44228, CVE-2021-45046	 Included
com.fasterxml.jackson.core:jackson-databind	Version bump	2.9.8 → 2.18.8	55 CVEs incl. CVE-2019-12086, CVE-2022-42003	 Included
commons-io:commons-io	Version bump	2.4 → 2.14.0	CVE-2021-29425, CVE-2024-47554	 Included
org.apache.commons:commons-lang3	Version bump	3.4 → 3.18.0	CVE-2025-48924	 Included
com.google.guava:guava	Version bump	24.1.1-jre → 32.0.1-jre	CVE-2020-8908, CVE-2023-2976	 Included

Not Included — Human Follow-Up Required

Coordinate	Reason	Action Required
------------	--------	-----------------

mysql:mysql-connector-java:8.0.30	MAJOR_REVIEW — no upstream fix for CVE-2023-22102 (CVSS 8.9); GPL-2.0 license violation	Replace with <code>com.mysql:mysql-connector-j:8.0.33</code> (commercial exception) or <code>org.mariadb.jdbc:mariadb-java-client</code> (LGPL)
log4j-core/api:2.17.1	3 new medium CVEs in 2.17.1, fix in 2.25.x	Future bump to 2.25.4 after breaking-change review
jackson-databind:2.18.8	GHSA-5jnj-h7xm-6q6v (Medium), fix in 2.18.9	Bump to 2.18.9 once published to Maven Central

Pre-existing gate failure: `mvn verify` fails JaCoCo line-coverage check (56% actual vs 80% required). This is ISSUE #6 in the project pom.xml — intentionally uncovered code, unrelated to dependency changes. `mvn clean test` passes.

CVE Re-Scan (Post-Fix)

Coordinate	Installed	Remaining	Notes
mysql-connector-java	8.0.30	HIGH — GHSA-m6vm-37g8-gqvh	No upstream fix; MAJOR_REVIEW
log4j-core	2.17.1	MEDIUM ×3	Newer findings; fix in 2.25.x
jackson-databind	2.18.8	MEDIUM ×1	GHSA-5jnj-h7xm-6q6v; 2.18.9 not yet on Central
All other deps	—	CLEAN	No remaining vulnerabilities

Stage 4 — Merge Gate

Gate runs against the PR for branch `fix/depSCAN-20260626-062022` . Gate verdict is posted as a PR review. See the PR for the full PASS/BLOCK decision.

Gate criteria (from depSCAN-merge-validation):

Check	Expected
<code>mvn test</code>	✓ PASS
OWASP/Grype: zero unresolved CRITICAL/HIGH on in-scope deps	⚠ mysql MAJOR_REVIEW — gate assesses
Supply-chain audit: no BLOCK-level findings	✓ Typosquat + untrusted repo removed

Human Follow-Up Actions (Ordered)

- [MAJOR_REVIEW — BLOCKING]** Replace `mysql:mysql-connector-java:8.0.30` — CVE-2023-22102 (CVSS 8.9, no upstream fix) + GPL-2.0 license violation. Recommended: `com.mysql:mysql-connector-j:8.0.33` (commercial exception) or `org.mariadb.jdbc:mariadb-java-client` (LGPL).
- [FOLLOW-UP]** Bump `log4j-core` + `log4j-api` 2.17.1 → 2.25.4 after breaking-change review (3 medium CVEs in 2.17.1).
- [FOLLOW-UP]** Bump `jackson-databind` 2.18.8 → 2.18.9 once published to Maven Central (1 medium GHSA-5jnj-h7xm-6q6v).
- [COVERAGE]** Increase test line coverage from 56% to ≥80% to clear the pre-existing JaCoCo gate (ISSUE #6 in pom.xml).